

(a) Marco integrativo GQM + PRAGMATIC para indicadores MITRE D3FEND

1. Propósito del marco

Este documento define un marco integrativo que combina la metodología Goal–Question–Metric (GQM) con los criterios PRAGMATIC para evaluar indicadores basados en MITRE ATT&CK y MITRE D3FEND desde el nivel nacional hasta el dato técnico.[web:3][web:5][web:18]

GQM asegura la trazabilidad desde objetivos estratégicos (por ejemplo, de una Estrategia Nacional de Ciberseguridad o de España Digital 2025) hasta preguntas concretas y métricas observables, mientras que PRAGMATIC permite juzgar la calidad práctica de cada métrica propuesta en términos de utilidad real.[web:17][web:20][web:21]

2. Resumen de la metodología GQM aplicada a D3FEND

En el contexto de MITRE D3FEND, GQM se aplica en tres niveles:

1. Goal (Objetivo): descripción de alto nivel alineada con la política pública o la estrategia organizativa (p.ej., “reducir el riesgo de incidentes graves” o “aumentar la cobertura de técnicas ATT&CK críticas”).[web:3][web:5]
2. Question (Pregunta): cuestiones específicas que, si se responden, permiten evaluar el grado de logro del objetivo (p.ej., “¿qué porcentaje de técnicas críticas tiene al menos una contramedida D3FEND efectiva?”).[web:5][web:8]
3. Metric (Métrica): datos cuantitativos u observables que responden a las preguntas (p.ej., “porcentaje de técnicas ATT&CK críticas con ≥ 1 control mapeado a D3FEND y desplegado”).[web:5][web:18]

La ontología D3FEND y las herramientas CAD proporcionan, además, una base estructurada para derivar métricas desde modelos de contramedidas y coberturas frente a ATT&CK.[web:1][web:19]

3. Resumen del enfoque PRAGMATIC

PRAGMATIC es un acrónimo que describe nueve criterios para evaluar la calidad de una métrica:

- Predictivo: ayuda a anticipar resultados futuros.
- Relevante: está directamente relacionada con los objetivos.
- Accionable: su variación sugiere acciones claras.
- Genuino: refleja la realidad, no sólo procesos documentales.
- Significativo (Meaningful): se entiende fácilmente por las partes interesadas.
- Preciso: está definida de manera clara y consistente.
- Oportuno (Timely): puede medirse con la frecuencia necesaria.
- Independiente: no induce comportamientos perversos o gaming obvio.
- Rentable (Cost-effective): su coste de medición es proporcionado al valor que aporta.

En este marco, cada métrica se califica de 1 (muy bajo) a 5 (muy alto) en cada criterio, acompañando las puntuaciones de una justificación breve.

4. Indicadores clave del informe MITRE D3FEND

Tomando como base el informe previo, se consideran cinco familias principales de indicadores:

4. Cobertura ATT&CK–D3FEND: grado en que las técnicas ATT&CK críticas están cubiertas por contramedidas D3FEND implementadas.[web:3][web:5][web:8]
5. Latencia de detección y respuesta: tiempos medios de detección (MTTD) y mitigación/recuperación (MTTR/MTTM) para incidentes críticos.[web:18][web:21]
6. Eficacia de mitigaciones: tasa de éxito de contramedidas D3FEND aplicadas y recurrencia de incidentes similares.[web:5][web:18]
7. Cobertura y calidad de telemetría: porcentaje de activos/artefactos relevantes con sensores adecuados y calidad de datos de detección.[web:1][web:19]
8. Métricas específicas OT/ICS: cobertura de rutas de mando y control, monitorización de protocolos industriales y tiempos de recuperación de funciones OT críticas.[web:5][web:20]

Cada familia se descompone en objetivos, preguntas y métricas concretas en la sección siguiente.

5. Aplicación GQM a indicadores MITRE D3FEND

5.1. Cobertura ATT&CK–D3FEND

Goal G1 (nacional / sectorial)

Aumentar y mantener un nivel adecuado de cobertura de técnicas ATT&CK críticas mediante contramedidas mapeadas a MITRE D3FEND, reduciendo el riesgo de incidentes graves en sectores esenciales.[web:3][web:5][web:23]

Questions

- Q1.1: ¿Qué porcentaje de técnicas ATT&CK críticas identificadas para el país/sector tiene al menos una contramedida D3FEND implementada en los operadores clave?
- Q1.2: ¿Qué porcentaje de técnicas ATT&CK críticas tiene coberturas sólo parciales (por ejemplo, detección sin mitigación o viceversa)?
- Q1.3: ¿Qué técnicas ATT&CK críticas carecen de contramedidas implementadas en al menos X % de organizaciones relevantes?

Metrics

- M1.1: Porcentaje de técnicas ATT&CK críticas con ≥ 1 contramedida D3FEND implementada (cobertura completa).
- M1.2: Porcentaje de técnicas ATT&CK críticas con cobertura parcial (por ejemplo, sólo detección o sólo endurecimiento).
- M1.3: Número y porcentaje de técnicas ATT&CK críticas sin contramedidas implementadas por sector.
- M1.4: Densidad de contramedidas por técnica crítica (nº medio de técnicas D3FEND implementadas por técnica ATT&CK crítica).[web:5][web:8][web:18]

5.2. Latencia de detección y respuesta

Goal G2 (nacional / organizativo)

Reducir los tiempos de detección y respuesta a incidentes críticos hasta niveles compatibles con la resiliencia de servicios esenciales.[web:18][web:21][web:23]

Questions

Q2.1: ¿Cuál es el tiempo medio de detección (MTTD) de incidentes críticos en organizaciones esenciales?

Q2.2: ¿Cuál es el tiempo medio de mitigación/recuperación (MTTR/MTTM) de incidentes críticos?

Q2.3: ¿Cómo evolucionan estos tiempos a lo largo del tiempo y tras iniciativas específicas (nuevas contramedidas D3FEND, mejora de telemetría, etc.)?

Metrics

M2.1: MTTD de incidentes críticos (minutos/horas).

M2.2: MTTR/MTTM de incidentes críticos (horas/días).

M2.3: Porcentaje de incidentes críticos detectados dentro de umbrales objetivo (p.ej., < 30 minutos).

M2.4: Variación porcentual de MTTD/MTTR tras la implantación de nuevas contramedidas D3FEND o mejoras de telemetría.[web:18][web:21]

5.3. Eficacia de mitigaciones

Goal G3 (organizativo / nacional)

Aumentar la eficacia de las contramedidas D3FEND en la neutralización de técnicas ATT&CK críticas, reduciendo la recurrencia de incidentes similares.[web:5][web:18]

Questions

Q3.1: ¿Qué proporción de intentos de mitigación de incidentes críticos logra neutralizar efectivamente la amenaza?

Q3.2: ¿Con qué frecuencia se repiten incidentes de tipo similar tras la aplicación de supuestas mitigaciones?

Q3.3: ¿Qué técnicas D3FEND muestran mayores tasas de éxito o fracaso en la práctica?

Metrics

M3.1: Tasa de éxito de mitigaciones (nº de incidentes críticos mitigados / nº total de intentos de mitigación).

M3.2: Indicador de recurrencia de incidentes (nº de incidentes similares en un periodo determinado tras la mitigación).

M3.3: Tasa de éxito por familia de técnica D3FEND (Detect, Harden, Deceive, Evict, etc.).[web:5][web:18]

5.4. Cobertura y calidad de telemetría

Goal G4 (técnico / organizativo)

Garantizar que los artefactos y flujos relevantes para técnicas ATT&CK críticas están adecuadamente instrumentados con sensores y telemetría de calidad suficiente para soportar las técnicas defensivas D3FEND.[web:1][web:19]

Questions

Q4.1: ¿Qué porcentaje de activos/artefactos asociados a técnicas ATT&CK críticas dispone de sensores adecuados?

Q4.2: ¿Cuál es la calidad de la telemetría (completitud, precisión, contexto) asociada a dichos sensores?

Q4.3: ¿Qué lagunas de telemetría impiden aplicar determinadas técnicas D3FEND?

Metrics

M4.1: Porcentaje de activos/artefactos críticos con sensores configurados según recomendaciones D3FEND.

M4.2: Porcentaje de flujos de datos críticos monitorizados.

M4.3: Indicador de calidad de telemetría (puntuación compuesta de completitud, precisión y contexto).

M4.4: Número de técnicas D3FEND no aplicables por falta de telemetría adecuada.[web:1][web:19]

5.5. Métricas específicas OT / ICS

Goal G5 (nacional / sector OT)

Incrementar la resiliencia de infraestructuras OT mediante la implantación y medición de contramedidas D3FEND específicas para sistemas industriales y ciberfísicos.[web:5][web:20]

Questions

Q5.1: ¿Qué porcentaje de rutas de mando y control industrial está cubierto por segmentación, monitorización y controles conforme a D3FEND?

Q5.2: ¿Qué porcentaje de protocolos industriales críticos está monitorizado según buenas prácticas?

Q5.3: ¿Cuál es el tiempo de recuperación de funciones OT críticas tras incidentes significativos?

Metrics

M5.1: Porcentaje de rutas de mando y control OT con controles y monitorización definidos según D3FEND.

M5.2: Porcentaje de protocolos industriales críticos con monitorización activa.

M5.3: Tiempo medio de recuperación de funciones OT críticas (MTTR-OT).

M5.4: Porcentaje de incidentes OT con pérdida de función limitada dentro de umbrales predefinidos.
[web:5][web:20]

6. Integración con objetivos nacionales y sectoriales

Los objetivos G1–G5 se pueden vincular directamente con metas habituales en estrategias nacionales de ciberseguridad y planes digitales nacionales (por ejemplo, España Digital 2025), tales como:

- Aumentar la resiliencia de servicios esenciales y entidades importantes.
- Reducir el impacto y la frecuencia de incidentes graves.
- Mejorar las capacidades de detección y respuesta.
- Fortalecer la seguridad de infraestructuras OT e industriales críticas.[web:17][web:20][web:23]

La combinación de GQM y PRAGMATIC permite, además, seleccionar y priorizar aquellas métricas que, además de coherentes con la ontología D3FEND, sean realmente útiles y sostenibles en el tiempo.